

1. On-prem app prepares the request

- Collects the file to scan
- Adds application authentication header:
 - `X-Api-Key: <api-key>`
- Uses a client certificate for **mTLS** (TLS client auth)

2. App submits the file for scanning

- Sends:
 - `POST https://scan.example.com/scan`
- Includes:
 - Request body = raw file bytes
 - Headers:
 - `X-Api-Key`
 - `Content-Type: application/octet-stream`
 - (optional) `X-Filename: <name>`

3. Cloudflare TLS layer enforces mTLS

- Client connects to `scan.example.com`
- Cloudflare requests a client certificate
- If client cert is missing/invalid:
 - TLS fails and the request never reaches HTTP

4. Cloudflare WAF Custom Rules gate the request

- Checks run before Worker logic:

- API key header **exists**
- Method is allowed:
 - **POST /scan**
- Request size is within limit
- If a rule fails:
 - Cloudflare blocks and returns a fixed status code (e.g., **401**, **405**, **413**)

5. Worker validates the API key value

- Worker compares **X-API-Key** to the expected value stored securely as a **Worker secret**
- If invalid:
 - Returns **401 Unauthorized**

6. Worker performs content scanning (PoC logic)

- Reads the uploaded bytes (PoC assumes small files)
- Applies scan logic (mock signature / rules)
- Generates a unique **scanId** for this scan request

7. Worker stores the scan outcome (ephemeral)

- Writes a temporary record keyed by **scanId** containing:
 - **verdict** (**clean** or **blocked**)
 - metadata (filename, timestamp)
 - the file bytes **only if clean** (PoC scope)
- Record is stored with a short TTL (minutes)

8. Worker returns a status code that represents the scan verdict

- Response includes:
 - HTTP status code + small JSON body (includes `scanId`)
- Status codes:
 - `200 OK` → clean
 - `406 Not Acceptable` → blocked
 - `500` → scan/internal error (if applicable)

9. On-prem app interprets the scan response

- If HTTP `200`:
 - Proceed to download the clean file
- If HTTP `406`:
 - Stop; treat file as blocked
- If `401/413/5xx`:
 - Handle as auth/size/system error

10. On-prem app downloads the file only when clean

- Sends:
 - `GET https://download.example.com/download?id=<scanId>`
- Includes:
 - `X-Api-Key: <api-key>`
 - (mTLS client certificate again if enabled on `download.example.com`)

11. Cloudflare enforces mTLS + WAF on download

- TLS validates client cert (if required)

- WAF validates:
 - API key header exists
 - Method is allowed: `GET /download`

12. Worker authorizes and serves the download

- Worker validates API key value again (secret-based)
- Looks up `scanId` record:
 - If verdict is `clean`:
 - Returns `200 OK` + file bytes
 - If verdict is `blocked`:
 - Returns `403 Forbidden`
 - If `scanId` is missing/expired:
 - Returns `404 Not Found`

13. PoC success criteria

- Demonstrate end-to-end:
 - Unauthorized requests blocked at edge
 - Clean uploads return `200` + valid `scanId`
 - Blocked uploads return `406`
 - Downloads only succeed for clean verdicts
 - TTL expiration results in `404` for old `scanIds`